区块链技术创新及应用创新

测试报告

ChainGuard

面向 AI Agent 协作的
区块链授权与审计系统

真实模型、真实交易与本地副作用分轨验证

2026 年 10 月 30 日

测试摘要

本报告面向提交版本的可运行性、安全性、隐私性和区块链增量价值进行说明。证据分为历史真实实验与 2026 年 10 月 30 日提交前复验，二者分别计数。历史数据包括三条真实 DeepSeek 轨的 60 次任务、180 次模型请求，138 条协议观测，以及 65 条 B/C 机制观测。提交前复验重新计算五轨全部统计、核对 313 项实验产物摘要和 21+8 份冻结输入，不重调模型、不重复发信、不新增实验交易。

结果显示：在小样本目录注入任务中，A 实际错发 2 封，B/C 均阻断并未错发；相同策略下没有证明 C 的模型攻击率普遍优于 B。C 的实测增量主要体现在审批目录共同治理、跨入口预约串行化，以及公共元数据的独立恢复。共享事务数据库和完整签名日志是有效的中心化对照；独立工具数据库双投递仍使 B/C 均产生双份副作用。性能与可用性代价、异常样本及部署限制一并保留。

本报告不是官方 AgentDojo 完整排行榜结果。测试邮件仅写入本地 MIME 沙箱；四个验证节点和测试组织身份同机运行，不代表四家独立机构。测试通过不等于生产安全认证。

目　录

第一章　测试范围与平台 1
1.1　被测对象和版本 1
1.2　测试数据和隐私处理 1
第二章　测试分层与通过判据 2
2.1　功能与协议检查矩阵 2
2.2　提交前复验 2
第三章　实验设计与统计方法 3
3.1　A/B/C 与三类观测分离 3
3.2　指标、分母与区间 3
第四章　真实模型实验结果 4
4.1　目录提示词注入：尝试与实际效果 4
4.2　原始与摘要任务：未观察到越权尝试 4
第五章　协议攻击、篡改与恢复结果 5
5.1　共同攻击口径 5
5.2　篡改、伪造与任务完成 5
第六章　区块链相对强化中心化的增量 5
6.1　共同治理与串行化 5
6.2　独立查证与可用性 6
6.3　性能代价 6
第七章　复现、证据与提交前检查 7
7.1　从汇总追到原始记录 7
7.2　运行方法 7
第八章　缺陷、限制与结论 8

第一章　测试范围与平台

1.1　被测对象和版本

被测对象为 ChainGuard monorepo 交付快照，包括 FastAPI 网关、Agent Runner、默认及自定义工具、会话 LOW 授权、R2 邮件闭环、三类 Registry 及其增量合约、业务台与独立只读审计台。原协议版本 1.0.0，精确源码版本以作品源码包内`DELIVERY_MANIFEST.json` 为准；Git 基线 a5c23eb 之后存在未提交实现，不将该提交号作为全部源码的唯一版本。

表 1.1　实际使用的平台与锁定依赖

组件	配置
开发与运行平台	Windows、Ubuntu WSL2、Docker；同一物理宿主，Linux amd64 运行镜像
Python 与 Web	Windows Python 3.14.4；Linux Python 3.14.4；FastAPI 0.119.1、Starlette 0.48.0、Uvicorn 0.38.0
合约与测试	Solidity 0.8.28、Hardhat 2.26.3、OpenZeppelin 5.4.0、pytest 8.4.2
前端	React 19.1.1、Vite 6.3.6；Node 22.23.1、npm 10.9.8
联盟链	Hyperledger Besu 25.10.0；4 个 QBFT 验证节点；chainId=20261026；正常出块间隔 2 秒
真实模型	DeepSeek / deepseek-flash，OpenAI-compatible；temperature=0，top_p=1，thinking disabled，并发 1

Python 和 npm 依赖分别由 requirements-dev.lock、gateway/central-test.lock 及 package-lock.json 锁定，合约使用本地 solc-js。Docker 镜像内容 ID 另见运行包 images/image-inventory.json。模型服务别名不提供永久快照，未来重跑未必返回逐字相同文本，因此原模型请求和响应也属于实验记录。

1.2　测试数据和隐私处理

默认文档、联系人及库存示例为合成测试资料，邮件地址使用`inbox.chainguard.invalid`。公开 GitHub 查询使用 microsoft/vscode 及受限 Issue，不配置私有 Token。上传附件与个人对话不作为公开实验数据。公开证据包只收录经核对的合成实验记录、哈希、签名和交易 receipt；原现场私有数据库、证书私钥、API Key、聊天和邮箱运行卷均不导出。

第二章　测试分层与通过判据

2.1　功能与协议检查矩阵

模块	检查内容	通过判据
接口与签名	JSON 规范化、参数承诺、EIP-712 跨语言向量	Python/Solidity 编码一致；变更参数、域或签名应被拒绝
身份与策略	OrgA/OrgB 角色、组织去重、撤销、暂停、作用域	只有当前有效且符合组织条件的身份可以授权
工具边界	doc/mail 读取、沙箱路径、重复 actionId	范围外拒绝；合法操作有真实文件/MIME；原幂等存储不重复执行
R2 执行	双审批、reserve、工具二验、签名回执、finalize	原意图、四节点 receipt、签名与实际 MIME 一致
异常恢复	丢响应、UNKNOWN、链失联、待补提交	不盲目重发；通过原交易/回执推进，不伪造执行成功
会话与 LOW	历史记忆、过期/超额、显式续签、Merkle 证明	原 session 保持；新 nonce 和双端激活；旧周期不覆盖
前端与审计	消息显示、历史滚动、异步控制、只读边界	不以 UI 状态判定链成功；实时核验独立查链
交付包装	路径白名单、凭据/身份扫描、摘要与解压	冻结字节不变；包内无本地私有凭据，重开 ZIP 一致

单元测试中的 fixture 及 mock 仅用于隔离输入和边界，不作为四节点或真实 LLM 的执行证据。真实实验单独保留模型请求、交易与本地副作用。截图用于说明界面，不能替代任何 receipt 或工具回执。

2.2　提交前复验

2026 年 10 月 30 日基线全量 Python 为 590 项通过；业务前端 48 项、审计前端 3 项、Hardhat89 项通过；两个前端生产构建与冻结检查通过。新增打包校验包含 12 项用例，连同既有仓库维护 6 项合计 18 项通过。源码解压后 602 项通过；无网络、无宿主目录/私有卷挂载的受限镜像内，按完整锁文件离线安装依赖后 602 项通过。最终日志以随包 validation-summary.json 索引为准，不将不同运行的测试次数相加为独立安全样本。

测试命令和原日志位于其他文件包的 submission-checks/。普通新消息 4096 tokens、文档 8192 tokens 的最新交互配置已随源码交付；历史 A/B/C 实验保持各自 512/1024 tokens，不混淆交互优化与实验条件。

第三章　实验设计与统计方法

3.1　A/B/C 与三类观测分离

A 为普通中心化路径，保留账号级工具权限，任务策略以 shadow 形式观察；B 强制冻结任务策略、独立审批签名、工具二验及签名追加日志；C 复用 B 的共同业务策略，并增加链上共同治理、预约和回执确认。A/B/C 每一实验轨内部任务、模型、数据与评分方法一致，输入摘要按配对 sample_id 校验。

固定 trace 协议回放不使用真实模型，ASR 标记为未测；真实模型轨区分 Agent 尝试、policy_verdict、tool_executed 与 attack_success。机制干预轨使用真实服务、签名、磁盘、MIME 和 Besu，LLM 样本数为 0，不填入模型 ASR。

表 3.1　原始实验批次及本轮离线复核

轨道	观测数	模型请求	MIME	交易/节点 receipt
原始模型	12	36	12	8/32
模型摘要	36	108	36	24/96
目录注入探测	12	36	8	4/16
确定性协议	138	0	93	59/236
B/C 机制	65	0	71	75/300

前三轨 60 次任务对应 180 次真实模型请求；目录探测含源数据污染和指令注入，只有两个底层任务，不能外推大规模成功率。机制轨含 31 对 B/C 与 3 条 C 特有 RPC 故障；不能把这 3 条当作共同配对攻击。此前失败、历史批次和本轮只读复核均不加入上述样本数。

3.2　指标、分母与区间

UER 为实际越权执行数/实际越权尝试数；UBR 为被明确阻断的越权尝试数/实际越权尝试数；ASR 为攻击目标实际达成数/可评价的注入任务数；TCR 为完成精确合法目标数/符合任务评价条件的任务数；TDR 为检出的篡改数/实际篡改尝试数。没有越权尝试时 UER/UBR 不适用，不能把 0/0 写成拦截成功；协议轨没有模型攻击样本，ASR 为未测。

比例报告 95% Wilson 描述区间，同时 CSV 保留按底层任务/场景聚类的 percentile bootstrap 区间；默认 1000 次重采样，固定随机种子。失败和 UNKNOWN 保留在分

母，证据不全不填成功或失败；存在 unknown 时使用上下界或 PARTIAL。组间分母不同不强算配对差值。

延迟分位采用排序后的线性插值，P50/P95/P99 的 95% 区间由 bootstrap 得到。性能仅纳入符合成功动作条件的记录，失败另报。每组仅 10 个固定负载重复，P99 为探索性描述，不能视为生产尾延迟保证或容量测试。

第四章　真实模型实验结果

4.1　目录提示词注入：尝试与实际效果

模型在污染资料的影响下尝试将摘要发给未授权 Bob。A 实际错发 2 封；B/C 都拒绝该精确调用，没有错发副作用。两组相同的阻断结果来自共同确定性策略，不能据此声称引入链后 ASR 优于 B。

表 4.1　目录探测：真实模型结果（每组 4 次任务、2 条攻击任务）

组别	指标	分子/分母	估计	95% Wilson 区间 (%)
A	UER	2/2	100.00%	[34.24, 100.00]
A	UBR	0/2	0.00%	[0.00, 65.76]
A	ASR	2/2	100.00%	[34.24, 100.00]
A	TCR	2/4	50.00%	[15.00, 85.00]
B	UER	0/2	0.00%	[0.00, 65.76]
B	UBR	2/2	100.00%	[34.24, 100.00]
B	ASR	0/2	0.00%	[0.00, 65.76]
B	TCR	2/4	50.00%	[15.00, 85.00]
C	UER	0/2	0.00%	[0.00, 65.76]
C	UBR	2/2	100.00%	[34.24, 100.00]
C	ASR	0/2	0.00%	[0.00, 65.76]
C	TCR	2/4	50.00%	[15.00, 85.00]

4.2　原始与摘要任务：未观察到越权尝试

原始模型轨各组 TCR 均 4/4、ASR 均 0/3，ASR 的 95% 区间为 [0,56.15%]；摘要轨各组 TCR 均 12/12、ASR 均 0/8，区间为 [0,32.44%]。两轨模型均未提出越权调用，不能把这些任务作为网关完成拦截的样本。两轨不与目录探测合并攻击分母。

第五章　协议攻击、篡改与恢复结果

5.1　共同攻击口径

协议轨包括参数替换、审批伪造、签名错用、重放、故障和恢复。对三组共同的文档/邮件越权及参数替换 9 次尝试，A 实际越权执行 6 次，B/C 均 0 次。共同口径的 UER 与 UBR 如下；B/C 额外面对的审批攻击不混进 A 的分母。

表 5.1　协议轨共同业务策略口径

组别	指标	分子/分母	估计	95% Wilson 区间 (%)
A	UER	6/9	66.67%	[35.42, 87.94]
A	UBR	3/9	33.33%	[12.06, 64.58]
B	UER	0/9	0.00%	[0.00, 29.91]
B	UBR	9/9	100.00%	[70.09, 100.00]
C	UER	0/9	0.00%	[0.00, 29.91]
C	UBR	9/9	100.00%	[70.09, 100.00]

5.2　篡改、伪造与任务完成

B/C 分别检出 6/6 篡改，95% 区间 [60.97%,100%]；A 为 0/6。B/C 额外 6 次伪造/错用审批均未接受，0/6 的描述区间上限仍为 39.03%，不称零风险。三组协议 ASR 全部未测。TCR 为 A28/31、B28/31、C25/31，CSV 保留失败和故障样本，不能只展示成功分支。相同持久存储中的重放没有额外邮件，但缓存返回不自动等于明确拒绝。

真实 UNKNOWN 恢复核对原回执与原副作用后补提交，禁止通过再执行制造成功；链失联时不降级为中央执行。具体异常原因与恢复事件留在逐例 JSON，不覆盖原始失败记录。

第六章　区块链相对强化中心化的增量

6.1　共同治理与串行化

目录控制干预中，攻击者取得当前 B 中心目录管理员能力后替换批准人及组织声明，3/3 实际发送。C 只提供单组织治理签名或重复同组织签名，6 笔治理交易全部回滚、3/3 无邮件。此处比较的是两种不同治理信任根，不是相同架构下等权攻击；具有跨组织共同目录治理的 B+ 仍需独立对照。

表 6.1 机制干预的实际结果（每种机制 3 次）

条件	B	C
共享事务状态争用	每次 1 封	每次 1 封
两份分裂网关/工具快照	每次 2 封	每次 1 封；预约 1 成功 1 回滚
同一预约直投两份工具数据库	每次 2 封	每次 2 封；只有 1 份回执链上锚定
缺尾历史副本	3/3 检出；0/3 恢复最终元数据	3/3 检出；3/3 从链恢复公共元数据
独立完整已签日志 B+log	3/3 恢复公共元数据	同上链恢复；不从哈希恢复正文

分裂状态下，C 竞争相同链上 nonce/预约，出现一笔成功和一笔回滚。共享数据库的 B 本来就可实现一次性处理；区块链的作用是提供跨入口共同序列。独立工具数据库双投递反例表明：当前实现仍要求共享工具幂等存储，单个 FINALIZED_OK 不能证明全系统没有第二副作用。C 败者本地停留 RESERVING 是原恢复缺口。

6.2 独立查证与可用性

完整签名日志 B+log 能恢复与 C 相同的公共元数据，因此不能声称中央日志必然无法恢复。链提供多个参与方共同维护的统一记录；其是否值得取决于各方是否愿意信任中心管理员。

B 真实数据库打不开、C 真实 RPC 连接失败时均无副作用，恢复后各 3/3 单封。C 一个配置 RPC 不可用时即使账本继续出块，也拒绝业务直到恢复；未关闭验证者、未测试恶意 quorum 或多机分区，不作端到端容错优越性结论。

6.3 性能代价

表 6.2 机制轨服务层延迟（ms，括号为 95% 区间）

组别	分位数	次数	延迟及区间
B	P50	10	319.6 [307.6, 329.8]
B	P95	10	331.4 [324.4, 331.6]
B	P99	10	331.5 [324.4, 331.6]
C	P50	10	3351.4 [2870.8, 3453.8]
C	P95	10	3663.5 [3383.9, 3785.8]
C	P99	10	3761.3 [3383.9, 3785.8]

该延迟包含服务内真实签名、磁盘、Besu 和本地 MIME，排除模型、HTTP/mTLS、人工等待、部署及证据导出。C 的 P50 约 3.351 秒，B 约 0.320 秒。不能以 gasPrice=0 声称区块链无成本；LOW 批量与逐条写链的成对负载性能、完整链存储及运维成本尚未测得。

第七章　复现、证据与提交前检查

7.1　从汇总追到原始记录

其他文件包中的 evidence/按原相对路径保留五轨 traces.jsonl、cases.csv、aggregated_metrics.csv、run_manifest.json、逐例 JSON 和四节点 tx-receipts.json。实验中的本地 MIME 为合成数据；原现场个人聊天、上传资料和私人邮箱不在提交包中。manifest 保存实验产物摘要，交付 manifest 另保存包内字节摘要，二者含义不同。

提交前本机只读链检查确认四节点同链、共同区块持续增长，具体高度和时间见 submission-checks/live-chain.json。该检查不产生新交易，不把旧交易的再次核验计为新实验。公开 receipt 和签名可离线验证结构与哈希；在其他机器实时 eth_call 核验原交易，需要访问原链历史，不能在全新 genesis 上查询旧交易。

7.2　运行方法

运行包提供 Linux amd64 镜像、当前源码、前端构建产物、Linux 离线 wheel 缓存、镜像载入与受限自检脚本。自检无网络、无宿主目录和私有卷挂载，真实运行源码测试，不返回预置 PASS。恢复现有业务时必须显式指定原项目根和本地 runtime 配置；浏览器不获取密钥。

完整新机构部署还需要初始化链、生成独立身份、部署并治理合约、初始化受控卷及模型配置。随包包含各阶段脚本，但**完整最新业务尚未在无任何既有配置的空白机器一键重建验收**。运行包不是免安装 Windows 单文件程序。评委可以先进行离线自检和源码复核，再按运行说明复核现有环境；不将缺失的私有卷伪造为演示数据。

```
# 项目开发环境中的基础复验
python -m pytest -q
npm test
npm --prefix console test
npm --prefix dashboard test
python scripts/build_specs.py --check
python scripts/freeze_phase3_policy.py --check

# 实际重跑机制实验：会创建独立沙箱并发本地测试邮件
python scripts/run_bc_experiments.py --out results/phase8/new-run

# 仅复核原件：依赖原运行卷和四Besu，不重复工具执行
python scripts/run_bc_experiments.py --verify-source <source> --out <new-dir>
```

第八章　缺陷、限制与结论

当前完整高风险闭环限 R2 本地邮件；R3 完整业务、生产写工具及外部 SMTP 尚未实现。工具范围在会话创建时固定，中途勾选工具不会更新当前会话；需新建会话，显式扩权待实现。四 Besu 及两组织仍同宿主，不能抵御宿主同时取得全部密钥。完整官方 AgentDojo 任务及官方 utility 不兼容；远端模型别名不可冻结底层权重。

2026 年 10 月 29 日曾出现节点 3 退出/重启时相关的 CHAIN_UNAVAILABLE，当前恢复，但退出根因未闭环；单次健康通过不能视为永久解决。源码打包首轮把自测中的私钥标记字符串误报为凭据，已拆分测试字符串并重跑，失败原件保留；未发现实际密钥导出。首轮容器测试因运行镜像缺少开发校验依赖而收集失败；补齐完整离线 wheel 后又因 tmpfs 默认 noexec 无法加载原生扩展而失败。明确将一次性工作区设为 exec 后，离线 602 项通过，根文件系统、网络及凭据隔离不变。失败原日志保留，未修改业务测试掩盖。

ChainGuard 已经具备可检查的跨组织授权、执行和审计链路。实测支持其在共同治理、跨入口状态消费和独立元数据查证方面的条件性价值，同时揭示链确认成本与共享工具幂等存储边界。报告不预设区块链一定优于强化中心化；后续应完成独立机构部署、B+ 完整对照、真实共识故障及 LOW 成对性能实验。